EUROPAS DIGITALE IDENTITÄTS-WALLET

DIE WALLET IM UNTERNEHMEN

So bereiten Sie Ihr Unternehmen auf
Europas neue digitale Identitäts-Wallet vor

EUDI-WALLET | ONBOARDING | DATENSCHUTZ | REGISTRIERUNG

ZIRLANDIA MILKOVIC

DIGITALE IDENTITÄT · EUDI-WALLET

DIE WALLET IM UNTERNEHMEN

So bereiten Sie Ihr Unternehmen auf Europas neue digitale Identitäts-Wallet vor

ZIRLANDIA MILKOVIC

Die Wallet im Unternehmen
So bereiten Sie Ihr Unternehmen auf Europas neue digitale Identitäts-Wallet vor

© 2026 Zirlandia Milkovic. Alle Rechte vorbehalten. Kein Teil dieses Buches darf ohne schriftliche Genehmigung vervielfältigt werden, ausgenommen kurze Zitate in Rezensionen.

Deutsche Erstausgabe, 2026. Recherchestichtag: 12. November 2026. Begleitende Ressource: GDPRGard.eu.

Dieses Buch bietet praktische Orientierung, keine Rechts-, Sicherheits- oder Datenschutzberatung. Alle Beispiele, Unternehmen und Personen in den Praxisszenarien sind fiktiv. Gesetze, Standards und nationale Wallets geben den Stand zum Recherchestichtag wieder und sollten anhand der aktuellen Rechtstexte und Dokumentation geprüft werden.

INHALT

Inhaltsverzeichnis

ZUM EINSTIEG

Rechtlicher Hinweis 4
Einleitung: Der Führerschein, den niemand fotografieren wollte 4
Für wen dieses Buch ist 6
So nutzen Sie dieses Buch 6
Der Zehn-Minuten-Check zur Wallet-Bereitschaft 7

KAPITEL

1. Was die Wallet ist und was nicht 9
2. Nachweise und Vertrauen: Warum eine signierte Antwort besser ist als ein Foto 14
3. Kunden-Onboarding mit der Wallet 19
4. Datenminimierung und Datenschutz 23
5. Registrierung als Relying Party 28
6. Wallet-basierte Prüfung integrieren 32
7. Wenn etwas schiefgeht 37
8. Ihr 90-Tage-Plan zur Wallet-Bereitschaft 41

ABSCHLUSS

Schlusswort: Ein besseres Geschäft, sorgfältig gebaut 45

ANHÄNGE

Anhang A: Inventar der Prüfabläufe 47
Anhang B: Register der Datenabfragen 48
Anhang C: Arbeitsblatt zur Registrierung als Relying Party 49
Anhang D: Formulierungen für die Kundschaft 51
Anhang E: Integrations-Checkliste 52
Anhang F: Tracker für die 90 Tage 53

RÜCKSEITE

Glossar 54
Ein Hinweis zu GDPRGard.eu 55
Über die Autorin 56
Anmerkungen und Quellen 57

Rechtlicher Hinweis

Dieses Buch bietet praktische, bildende Orientierung für Anbieter digitaler Dienste, Online-Unternehmen und die Teams, die deren Registrierung, Onboarding und Identitätsprüfung gestalten und betreiben. Es ist weder Rechts-, Aufsichts-, Datenschutz-, Geldwäscheprävention- noch Vergabeberatung und begründet kein Beratungsverhältnis zwischen der Autorin und den Lesenden.

Die Europäische Brieftasche für die Digitale Identität (EUDI-Wallet) ist ein bewegliches Ziel. Das Gesetz gilt, aber die technischen Standards, die nationalen Wallets, die Register der vertrauenden Beteiligten und die Erwartungen der Aufsichtsbehörden werden noch fertiggestellt und ändern sich auch nach Drucklegung dieses Buches. Datumsangaben, Artikelnummern, Spezifikationsnamen und Versionsnummern geben den Stand zum Recherchestichtag am Ende des Buches wieder; einige stammen aus Sekundärquellen und nicht aus dem Amtsblatt. Lesen Sie, bevor Sie etwas entwerfen, kaufen oder zusagen, den aktuellen Text, die Hinweise Ihrer nationalen Behörde und die Dokumentation Ihrer Anbieter – und lassen Sie sich beraten, wenn Sie in einem regulierten Sektor tätig sind.

Wenn Sie die Schritte in diesem Buch befolgen, wird Ihr Onboarding einfacher, sicherer und leichter zu verteidigen. Es kann jedoch nicht garantieren, dass eine Aufsichtsbehörde, ein Bankpartner oder ein Prüfer jeder Entscheidung zustimmt, und keine Checkliste ersetzt eine Entscheidung, die nur Ihre Rechtsberatung, Ihre oder Ihr Datenschutzbeauftragter oder Ihre Aufsichtsbehörde treffen kann.

Jedes Unternehmen, jede Person und jeder Vorfall in einem Praxisbeispiel ist **fiktiv** und als solcher gekennzeichnet. Reale Gesetze, Standards und Aussagen sind in den Anmerkungen am Ende des Buches belegt, zusammen mit einer ehrlichen Liste dessen, was die Autorin nicht überprüfen konnte.

Einleitung: Der Führerschein, den niemand fotografieren wollte

Marta leitet Adria Drive, einen Autovermieter mit vierzehn Beschäftigten an der dalmatinischen Küste. Jeden Sommer buchen ihre Kundinnen und Kunden online, kommen an den Schalter und warten, während eine

erschöpfte Mitarbeiterin einen Führerschein fotografiert, einen Reisepass prüft, ein Geburtsdatum abtippt und darum bittet, für ein Selfie das Telefon hochzuhalten. An einem guten Tag dauert das elf Minuten. Im Juli ist es der Grund für Ein-Stern-Bewertungen.

Im vergangenen Winter stellte ein Kunde aus München eine Frage, die sie innehalten ließ. „Kann ich Ihnen den Führerschein einfach aus meiner Wallet auf dem Handy zeigen? Ich habe den europäischen."

Sie konnte es nicht. Sie wusste nicht, ob sie es überhaupt durfte. Sie wusste nicht, was der Kunde ihr zeigen würde, was sie erhalten würde, was sie behalten dürfte oder was die Aufsichtsbehörde sagen würde, wenn sie das Falsche behielte. Sie vermutete, dass Kunden wie er innerhalb von zwei Jahren keine Ausnahme mehr sein würden.

Diese Vermutung ist richtig, und sie ist der Grund für dieses Buch. Nach der überarbeiteten eIDAS-Verordnung muss jeder EU-Mitgliedstaat seinen Bürgerinnen und Bürgern sowie Einwohnern bis Ende 2026 mindestens eine **Europäische Brieftasche für die Digitale Identität** (kurz **EUDI-Wallet**) zur Verfügung stellen, und bestimmte Unternehmen werden etwa ein Jahr später zu deren Akzeptanz verpflichtet sein.[1][2] Andere Unternehmen müssen sie überhaupt nicht akzeptieren, werden aber feststellen, dass Kundinnen und Kunden erwarten, sie nutzen zu können.

Die meisten Texte über die Wallet kommen aus zwei Richtungen. Politikexperten erklären das Gesetz. Ingenieure erklären die Protokolle. Fast niemand erklärt die Mitte: Was muss ein **Unternehmen** entscheiden, und in welcher Reihenfolge, um vorbereitet zu sein? Welche Ihrer Onboarding-Schritte könnte die Wallet ersetzen? Welche Daten sollten Sie verlangen, und welche Abfragen müssen Sie einstellen? Was bedeutet die Registrierung als „Relying Party" (vertrauende Beteiligte)? Wer trägt die Verantwortung, wenn der Nachweis falsch ist? Was sagen Sie der Kundin, die keine Wallet hat oder deren Telefon leer ist?

Dieses Buch beantwortet diese Fragen in verständlichem Deutsch. Es macht Sie nicht zur Kryptografin. Es gibt Ihnen einen belastbaren Weg zur **Vorbereitung**: eine Landkarte des Wallet-Ökosystems, eine Methode, um zu entscheiden, welche Daten Sie abfragen, einen klaren Blick auf die Datenschutzregeln, an denen Sie gemessen werden, einen Weg durch die Registrierung, realistische Integrationsoptionen und einen Neunzig-Tage-Plan, mit dem Sie am Montag beginnen können.

Ihnen wird nicht gesagt, die Wallet löse alles. Das tut sie nicht. Sie macht Ihre Kundenprüfungen nicht von selbst rechtmäßig, Ihre Betrugskontrollen nicht von selbst ausreichend und Ihre Datenschutzbilanz nicht von selbst sauber. Was sie leisten kann: Sie ersetzt das Foto einer Plastikkarte, aufgenommen

von einer fremden Person und von Ihnen unbegrenzt gespeichert, durch eine kleine, signierte, konkrete Antwort auf eine konkrete Frage. Das ist für Kundschaft und Unternehmen das bessere Geschäft – vorausgesetzt, Sie bauen es sorgfältig.

Für wen dieses Buch ist

Dieses Buch richtet sich an Menschen, die den Registrierungs- und Identitätsablauf eines Unternehmens verantworten, das an Menschen in Europa verkauft:

- **Gründerinnen, Gründer und Produktverantwortliche** von Online-Unternehmen, Marktplätzen, Fintechs, Reise- und Mobilitätsanbietern, Abo-Diensten und Plattformen.
- **Verantwortliche in Betrieb, Compliance und Datenschutz**, die gefragt werden: „Sind wir für die Wallet bereit?“ und etwas Besseres brauchen als eine Anbieterbroschüre.
- **Entwicklerinnen, Entwickler und technische Leitungen**, die die Wallet-gestützte Prüfung integrieren werden und den geschäftlichen und rechtlichen Zusammenhang kennen wollen, bevor sie eine Spezifikation lesen.
- **Anbieter digitaler Dienste jeder Größe**, vom Start-up mit zehn Personen bis zum regionalen Unternehmen, die kein Identitätsteam haben.

Sie müssen nicht technisch versiert sein. Wo ein Fachbegriff wichtig ist, wird er einmal in einfachen Worten erklärt und im Glossar gesammelt. Sie sollten aber grundlegend wissen, wie Ihr eigenes Onboarding heute funktioniert. Wenn Sie die Bildschirme beschreiben können, die Kundinnen und Kunden sehen, und die Dokumente, die Ihre Mitarbeitenden bearbeiten, wissen Sie genug.

Es ist nicht für Wallet-Anbieter, nationale Aussteller oder Zertifizierungsstellen geschrieben. Diese haben ihre eigenen detaillierten Spezifikationen. Es ist auch keine juristische Abhandlung. Es sagt Ihnen, welche Fragen Sie Ihrer Rechtsberatung in welcher Reihenfolge stellen sollten – das ist meist der Teil, den man überspringt.

So nutzen Sie dieses Buch

Die acht Kapitel folgen der Reihenfolge, in der ein Unternehmen tatsächlich vor den Entscheidungen steht:

1. **Was die Wallet ist und was nicht.** Das Ökosystem, der Zeitplan und wer wozu verpflichtet ist.
2. **Nachweise und Vertrauen.** Was eine Wallet enthält, wer sie ausstellt und warum eine signierte Antwort besser ist als ein Foto.
3. **Kunden-Onboarding.** Wo die Wallet in Registrierung, Altersprüfung, Kontoeröffnung und Übergaben wie bei der Fahrzeugmiete passt.
4. **Datenminimierung und Datenschutz.** Nur das Nötigste abfragen und die DSGVO-Pflichten, die damit einhergehen.
5. **Registrierung als Relying Party.** Was Sie angeben müssen, gegenüber wem und wie Sie es aktuell halten.
6. **Wallet-basierte Prüfung integrieren.** Selbst bauen, kaufen oder anbinden, und wie der technische Ablauf im Überblick aussieht.
7. **Wenn etwas schiefgeht.** Rückfalloptionen, gescheiterte Prüfungen, Betrug, Barrierefreiheit und Support.
8. **Ihr 90-Tage-Plan zur Wallet-Bereitschaft.**

Die Anhänge sind Arbeitsdokumente: ein Inventar der Prüfabläufe, ein Register der Datenabfragen, ein Registrierungsarbeitsblatt, eine kundengerichtete Erläuterung, eine Integrations-Checkliste und ein Neunzig-Tage-Tracker. Kopieren Sie sie, füllen Sie sie aus und halten Sie sie aktuell.

Achten Sie auf die dunklen Kästen mit der Überschrift **Die Regel**. Jeder nennt in einem Satz das Prinzip, um das sich ein Kapitel dreht. Wenn Sie sonst nichts lesen, lesen Sie diese.

Der Zehn-Minuten-Check zur Wallet-Bereitschaft

Beantworten Sie diese Fragen ehrlich, bevor Sie Kapitel 1 lesen. Ein „Nein“ oder „Weiß ich nicht“ ist kein Versagen, sondern der erste Punkt Ihrer To-do-Liste.

Frage	Ja	Nein / unsicher
Können Sie jede Stelle auflisten, an der Sie Kundinnen oder Kunden bitten, zu belegen, wer sie sind oder etwas über sich?		
Wissen Sie bei jeder Stelle, **warum** Sie fragen und welches Gesetz oder welches Risiko es verlangt?		
Wissen Sie, ob Sie rechtlich zur *starken* Authentifizierung Ihrer Kundschaft **verpflichtet** sind (regulierter Sektor)?		

Frage	Ja	Nein / unsicher
Speichern Sie Scans oder Fotos von Ausweisdokumenten? Wissen Sie, wie lange und warum?		
Könnten Sie eine davon durch eine einzige Ja/Nein-Antwort ersetzen (zum Beispiel „über 18“)?		
Wissen Sie, welche Vorschriften welches Mitgliedstaats für Ihre Niederlassung gelten und wer Ihre Aufsichtsbehörde ist?		
Gibt es eine benannte Person, die für Entscheidungen zur Identitätsprüfung verantwortlich ist?		
Haben Sie das Onboarding je mit jemandem getestet, der kein Smartphone oder ein defektes hat?		
Könnten Sie in zwei für Kundschaft verständlichen Sätzen erklären, was Sie bei der Wallet abfragen und was nicht?		
Würde Ihr heutiger Identitätsanbieter Ihnen seinen Plan für die Wallet nennen, wenn Sie heute fragten?		

Auswertung. Sieben oder mehr „Ja“: Sie sind voraus, und das Buch hilft beim Feinschliff. Vier bis sechs: typisch, und die Kapitel schließen die Lücken. Drei oder weniger: Beginnen Sie diese Woche mit Anhang A, denn einen Wallet-Ablauf kann man nicht um Prüfungen herum entwerfen, die man nicht erfasst hat.

KAPITEL 1

Was die Wallet ist und was nicht

KAPITEL 1
WAS DIE WALLET IST, UND WAS NICHT

Eine Brücke ist ein gutes Bild für die Wallet: Sie ersetzt keines der beiden Ufer, sie lässt etwas Vertrauenswürdiges hinübergelangen

Beginnen wir mit der einfachsten Beschreibung, die noch zutrifft. Die **Europäische Brieftasche für die Digitale Identität**, meist **EUDI-Wallet** genannt, ist eine App, die ein Mensch auf dem eigenen Gerät trägt. Darin lassen sich digitale Fassungen der eigenen Identität und anderer Tatsachen über die Person ablegen: Name und Geburtsdatum, ein Führerschein, ein Abschlusszeugnis, ein Wohnsitznachweis, ein Ticket. Braucht später ein Unternehmen eine dieser Angaben, entscheidet die Person, ob sie sie teilt, und die Wallet sendet eine kryptografisch **signierte** Antwort.[1]

Das Wort *signiert* ist der Kern. Wenn Sie einen Reisepass fotografieren, erhalten Sie ein Bild. Sie müssen dann entscheiden, ob das Bild echt ist, und Sie sitzen auf allem, was darauf steht. Wenn Sie einen Wallet-Nachweis erhalten, erhalten Sie Daten, die sich mathematisch gegen den Aussteller prüfen lassen. Sie wissen, wer dafür einsteht, Sie wissen, dass nichts verändert wurde, und Sie können nur das Stück anfordern, das Sie brauchen.

Die Beteiligten im Überblick

Das Wallet-Ökosystem hat mehr Akteure, als ein Anmelde-Button vermuten lässt. Sie begegnen diesen Rollen immer wieder, also lernen Sie sie jetzt kennen.

Wer was tut: Der Aussteller bürgt, die Person trägt, das Unternehmen prüft

- **Die Nutzerin oder der Nutzer** (die *Inhaberin* oder der *Inhaber*). Ein Mensch, der sich entscheidet, eine Wallet zu installieren und Nachweise darin abzulegen. Die Nutzung der Wallet ist für Privatpersonen freiwillig.[1]
- **Der Wallet-Anbieter.** Die Organisation, die die Wallet-App bereitstellt. Jeder Mitgliedstaat muss mindestens eine Wallet anbieten, entweder vom Staat selbst oder von einem beauftragten oder anerkannten Anbieter. Wallet-Anbieter sollen nicht sehen können, was Nutzende teilen, und nicht verfolgen können, wo die Wallet verwendet wird.[1]
- **Der PID-Anbieter.** PID steht für **Personenidentifizierungsdaten**: den Kern-Identitätsdatensatz wie Name und Geburtsdatum, ausgestellt von oder im Auftrag eines Mitgliedstaats.
- **Aussteller von Attributsbescheinigungen.** Alle, die eine geprüfte Tatsache über eine Person ausstellen: eine Führerscheinstelle, eine Hochschule, ein Arbeitgeber, eine Bank. Diese Tatsachen heißen **elektronische Attributsbescheinigungen**. Manche werden von *qualifizierten* Anbietern ausgestellt und haben größeres rechtliches Gewicht.
- **Relying Parties (vertrauende Beteiligte).** Das sind **Sie**. Eine Relying Party ist jedes Unternehmen oder jede öffentliche Stelle, die bei einer Wallet Daten abfragt, um eine Leistung zu erbringen. Die Verordnung kennt diese Rolle und knüpft eigene Pflichten daran, weshalb Kapitel 5 ihr gewidmet ist.[3]
- **Aufsichtsstellen und Register.** Jeder Mitgliedstaat bestimmt, wer das Ökosystem beaufsichtigt und das nationale Register führt, in dem Relying Parties angeben, was sie abfragen wollen.

Die Rollen können sich überschneiden. Eine Bank kann eine Bescheinigung über ein Konto ausstellen und sich zugleich auf die Wallet stützen, um ein Konto zu eröffnen. Eine Hochschule kann ein Diplom ausstellen und sich auf

eine PID stützen, um jemanden zu immatrikulieren. Entscheidend ist, dass Sie in jedem Ablauf wissen, welche Rolle Sie spielen.

Was die Wallet nicht ist

Missverständnisse kosten Unternehmen Geld, also deutlich gesagt:

Sie ersetzt nicht die Kenntnis Ihrer eigenen Rechtspflichten. Die Wallet kann vertrauenswürdige Daten liefern. Sie entscheidet nicht, ob Sie ein Konto eröffnen dürfen, ob eine Kundin auf einer Sanktionsliste steht oder ob Ihre Geldwäschepräventionsverfahren ausreichen. Diese Pflichten bleiben bei Ihnen. Ob und wie ein Wallet-Nachweis eine bestimmte Pflicht zur Kundensorgfalt erfüllen kann, ist eine Frage an Ihre Aufsichtsbehörde und Ihre Branchenregeln, nicht an dieses Buch.[9]

Sie ist für Menschen nicht verpflichtend. Privatpersonen können nicht zur Nutzung gezwungen werden, und Sie dürfen die Weigerung nicht zum Anlass nehmen, eine Leistung zu verweigern, wo ein gleichwertiger Weg vorgeschrieben ist. Planen Sie für Kundschaft, die nie eine Wallet installieren wird.

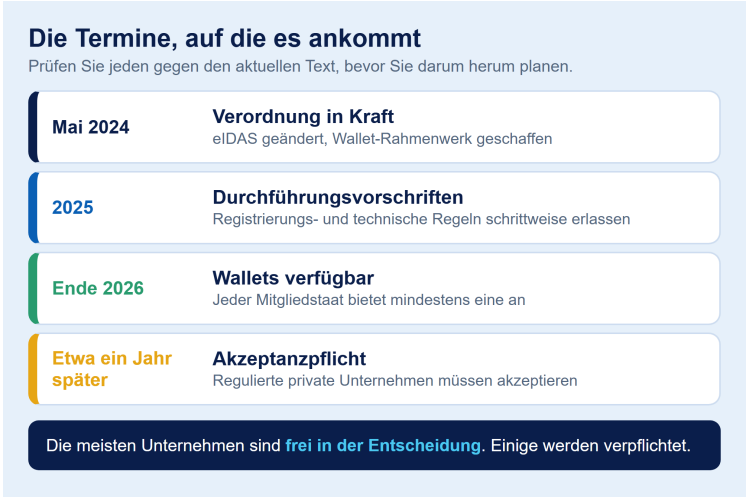
Sie ist kein universelles Login. Die Wallet ist darauf ausgelegt, *Attribute und Nachweise* zu teilen. Sie lässt sich zur Authentifizierung nutzen, ist aber nicht dazu gedacht, ein neues Social Login zu werden, das Menschen durchs Netz folgt.

Sie ist nicht eine App. Sie ist ein Rahmenwerk. Die Mitgliedstaaten stellen eigene Wallets bereit, gebaut nach gemeinsamen technischen Regeln, sodass eine kroatische Wallet von einem niederländischen Unternehmen gelesen werden kann. Rechnen Sie mit kleinen Unterschieden bei Aussehen, Einstellungen und Support.

Sie ist nicht fertig. Der Gesetzestext steht. Die technischen Standards, die nationalen Umsetzungen und die Register werden noch vervollständigt und getestet. Ein vernünftiges Unternehmen bereitet sich jetzt vor, baut in kleinen Schritten und legt sich nicht auf einen endgültigen Entwurf fest, bevor die Spezifikationen, von denen es abhängt, stabil sind.

Der Zeitplan und wer was tun muss

Die Verordnung, die die Wallet geschaffen hat, die Verordnung (EU) 2024/1183, trat im Mai 2024 als Änderung der ursprünglichen eIDAS-Verordnung in Kraft.[1] Für ein Unternehmen sind mehrere Termine wichtig.



Die Termine, auf die es ankommt: vom Inkrafttreten bis zur Akzeptanzpflicht für regulierte Unternehmen

- **Bis Ende 2026** muss jeder Mitgliedstaat mindestens eine Wallet bereitstellen. Quellen nennen den 24. Dezember 2026 als Arbeitsdatum; der genaue Termin hängt davon ab, wann die ersten Durchführungsrechtsakte wirksam wurden. Die Kommission hat selbst eingeräumt, dass nicht jedes Land am ersten Tag mit einer voll ausgestatteten Wallet bereitstehen wird.[2]
- **Etwa ein Jahr später** beginnt für bestimmte private Relying Parties die Pflicht, die Wallet zu **akzeptieren**. Das sind im Wesentlichen Unternehmen, die nach EU-Recht, nationalem Recht oder vertraglich bereits zur *starken Nutzerauthentifizierung* ihrer Kundschaft verpflichtet sind. Die Rechtsvorschriften nennen als Beispiele Bankwesen, Finanzdienstleistungen, Verkehr, Energie, Gesundheit, Telekommunikation, Bildung und digitale Infrastruktur.[2]
- **Sehr große Online-Plattformen** sollen die Wallet akzeptieren, wenn Nutzende sich damit freiwillig authentifizieren möchten, nach einem früheren Zeitplan als die allgemeine Akzeptanzpflicht.[2]
- **Alle anderen** haben keinerlei Pflicht, die Wallet zu akzeptieren. Sie können sich dafür entscheiden, und für einen wachsenden Teil der Kundschaft werden Sie das wollen.

Diese letzte Gruppe ist die große Mehrheit der Unternehmen, die dieses Buch lesen. Ihre Frage lautet nicht „Werden wir gezwungen?“, sondern „Lohnt es sich, und was ist der risikoärmste Einstieg?“ Kapitel 8 beantwortet das mit einem Plan. Wenn Sie in einem regulierten Sektor tätig sind, lautet Ihre Frage „Bis wann und für welche Abläufe?“, und die Antwort kommt aus Ihrer eigenen Rechtsanalyse, nicht aus diesem Kapitel.

Die Regel: Wissen Sie, in welcher von drei Situationen Sie sind: zur Akzeptanz verpflichtet, wahrscheinlich gefragt oder frei in der Entscheidung. Jede führt zu einem anderen Plan.

Warum sich der Aufwand lohnt, auch ohne Pflicht

Drei Gründe kehren wieder, und keiner hat mit Modetrends zu tun.

Sie nimmt Ihnen Daten ab, die Sie nicht halten sollten. Jeder gescannte Reisepass in Ihrem Speicher ist eine Belastung: ein Angriffsziel bei einem Datenleck, eine Frage der Aufbewahrung und ein Auskunftsersuchen, das nur darauf wartet, gestellt zu werden. Eine Wallet-Antwort kann sagen „Diese Person ist über 18“, ohne Ihnen ein Geburtsdatum, ein Foto oder eine Dokumentennummer zu übergeben.

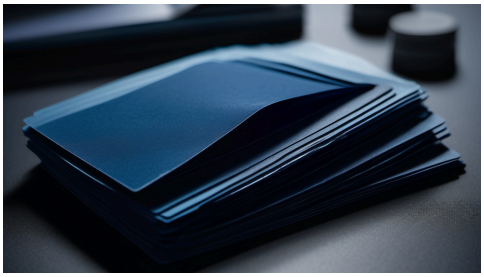
Sie senkt Reibung dort, wo sie Sie am meisten kostet. Martas Warteschlange am Schalter ist das Beispiel, aber dasselbe gilt für altersbeschränkte Verkäufe, die Kontoeröffnung und jede Registrierung, bei der Kundschaft am Identitätsschritt abspringt.

Sie verbessert die Qualität dessen, was Sie erhalten. Ein signierter Nachweis einer amtlichen Stelle ist schwerer zu fälschen als das Foto eines solchen. Betrug mit bearbeiteten Bildern und geliehenen Dokumenten hat es gegen Kryptografie schwerer.

Nichts davon ist umsonst. Sie werden Aufwand in Integration, Registrierung, Datenschutzdokumentation und Support stecken. Die nächsten Kapitel zeigen, wohin dieser Aufwand fließt, damit Sie mit offenen Augen entscheiden können.

KAPITEL 2

Nachweise und Vertrauen: Warum eine signierte Antwort besser ist als ein Foto



Ein Nachweis in der Wallet ist eher eine versiegelte Karte als ein Foto: Das Siegel ist der Punkt

Um einen guten Ablauf zu entwerfen, brauchen Sie ein funktionierendes Bild davon, was in einer Wallet steckt und warum man dem vertrauen kann. Die Mathematik brauchen Sie nicht. Sie brauchen vier Gedanken.

Gedanke eins: Nachweise werden ausgestellt, gehalten und vorgelegt

Drei Verben beschreiben den ganzen Lebenszyklus.

1. **Ausgestellt.** Ein Aussteller, etwa die Behörde, die Führerscheine erteilt, erstellt einen Nachweis und signiert ihn. Die Signatur ist das Siegel des Ausstellers.
2. **Gehalten.** Die Person erhält den Nachweis in ihre Wallet, wo er auf ihrem Gerät bleibt, geschützt durch die Gerätesicherheit.
3. **Vorgelegt.** Wenn ein Unternehmen fragt, stimmt die Person zu, und die Wallet sendet eine Präsentation, die belegt, dass der Nachweis echt und unverändert ist und dass er der Person gehört.

Sie als Unternehmen nehmen nur am dritten Schritt teil. Die ersten beiden sehen Sie nie. Das ist eine Entlastung, aber auch ein Risiko: Sie verlassen sich auf Parteien, die Sie nicht einsehen können. Deshalb ist der nächste Gedanke wichtig.

Gedanke zwei: Sie prüfen das Siegel, nicht das Wort der Person

Wenn eine Präsentation eintrifft, prüft Ihre Software drei Dinge:

- **Ist die Signatur gültig?** Wurde dieser Nachweis wirklich von dem Aussteller erstellt, der er zu sein vorgibt?
- **Ist der Aussteller vertrauenswürdig?** Steht er auf den Vertrauenslisten, die das Rahmenwerk führt? Eine einwandfreie Signatur eines unbekannten Ausstellers bedeutet nichts.
- **Ist er noch gültig?** Ist er abgelaufen, widerrufen oder ausgesetzt worden?

Kaufen Sie diese Leistung ein, erledigt der Anbieter diese Prüfungen für Sie. Bauen Sie selbst, setzen Ihre Entwickler sie mit einer Bibliothek um. In beiden Fällen sollten Sie in einem Satz sagen können, wie jede Prüfung erfolgt. „Das macht der Anbieter“ ist keine Antwort, die eine Aufsichtsbehörde allein akzeptiert.

Gedanke drei: Verschiedene Nachweisarten, verschiedenes Gewicht

Nicht alles in einer Wallet wiegt gleich. Halten Sie drei Kategorien auseinander.

Drei Arten von Nachweisen und wie viel jede in Ihrem Prozess zählen sollte

Personenidentifizierungsdaten (PID). Der Kern-Identitätsdatensatz, ausgestellt unter der Verantwortung eines Mitgliedstaats. Er enthält einen kleinen Satz Pflichtattribute zur Person, etwa Familienname, Vornamen,

Geburtsdatum, Geburtsort und Staatsangehörigkeit, mit optionalen Ergänzungen.[4] Das ist das, was einer digitalen Reisepassseite am nächsten kommt.

Qualifizierte elektronische Attributsbescheinigungen. Tatsachen, die von einem qualifizierten Vertrauensdiensteanbieter oder einer öffentlichen Stelle ausgestellt werden: ein Diplom, eine Berufszulassung, in manchen Ländern ein Führerschein. Sie haben nach der PID die stärkste rechtliche Grundlage.

Sonstige elektronische Attributsbescheinigungen. Tatsachen, die jede Organisation ausstellen kann: eine Mitgliedskarte, ein Treuestatus, ein Arbeitgeberschreiben. Sie sind nützlich, aber die Entscheidung, wie sehr Sie sich auf eine solche verlassen, ist eine **geschäftliche** Entscheidung. Ein Fitnessstudio-Nachweis belegt die Mitgliedschaft, und sonst nichts.

Jeder Ihrer Abläufe sollte benennen, welche Kategorie er braucht. „Wir müssen wissen, dass diese Person über 18 ist“ ist eine Frage vom PID-Typ oder eine, die eine vertrauenswürdige Altersbescheinigung beantworten kann. „Wir müssen wissen, dass diese Person fahren darf“ ist eine Frage an eine Attributsbescheinigung. „Wir müssen wissen, dass diese Person Kundin bei uns ist“ können Sie wahrscheinlich bereits selbst beantworten, ganz ohne Wallet.

Gedanke vier: Selektive Offenlegung ist die Funktion, die Ihr Design verändert

In der Papierwelt zeigt ein Führerschein, den Sie zum Altersnachweis vorlegen, auch Ihre Adresse, Ihre Führerscheinnummer und jede Klasse, die Sie besitzen. Einen Teil der Karte können Sie nicht verbergen. In einer Wallet kann ein Nachweis so aufgebaut sein, dass die Person **nur einige seiner Attribute** offenlegt oder sogar nur eine abgeleitete Antwort, während Sie die Signatur des Ganzen weiterhin prüfen können.[4]

Selektive Offenlegung: Die Wallet beantwortet die gestellte Frage und behält den Rest für sich

Die anfänglichen Nachweisformate der Wallet, beschrieben im Architekturrahmen, sind zwei: ein auf **SD-JWT** beruhendes Format, das für selektive Offenlegung entworfen wurde, und das Format **Mobile Document (mdoc)** aus dem Standard ISO 18013-5, das auch digitale Führerscheine antreibt.[4] Sie müssen sich als Unternehmen nicht zwischen ihnen entscheiden. Ihre Integration, ob gebaut oder gekauft, beherrscht in der Regel beide. Sie müssen die Konsequenz verstehen: **Die Technik erlaubt es Ihnen, weniger zu fragen, und das Gesetz wird es von Ihnen erwarten.**

> **Die Regel:** Wenn ein Ablauf mit einem Ja/Nein oder einem einzelnen Attribut beantwortet werden kann, ist es nicht nur verschwenderisch, ihn für das ganze Dokument zu entwerfen. Es ist genau das, was einer Aufsichtsbehörde auffallen wird.

Woher das Vertrauen tatsächlich kommt

Ein letzter Punkt, denn hier irren die meisten. Die Wallet macht einen Menschen **nicht** vertrauenswürdig. Sie macht eine *Behauptung* vertrauenswürdig: „Diese Behörde sagt, das Geburtsdatum dieser Person ist dieses." Ob die Person an Ihrem Schalter oder in Ihrem Formular *dieselbe* ist, die der Nachweis beschreibt, ist eine eigene Frage, beantwortet dadurch, wie die Wallet den Nachweis an die Inhaberin bindet, und durch zusätzliche Prüfungen, die Ihr Risikoniveau verlangt.

Bei einer Fahrzeugübergabe ist das sehr wichtig. Ein Führerscheinnachweis belegt, dass ein Führerschein existiert. Ihr Prozess muss weiterhin entscheiden, ob die Person, die das Auto abholt, dessen Inhaberin ist. Wallet-gestützte Abläufe machen das meist einfacher, weil der Nachweis an ein

Gerät und einen Entsperrschritt gebunden ist. Aber „einfacher“ heißt nicht „automatisch“, und die Risikobewertung in Kapitel 3 ist der Ort, an dem Sie entscheiden, wie weit Sie vertrauen.

KAPITEL 3

Kunden-Onboarding mit der Wallet

Die Spitze der Warteschlange ist der Ort, an dem Identitätsprüfungen am meisten kosten, an Zeit und Wohlwollen

Das Onboarding ist der Ort, an dem die meisten Unternehmen der Wallet zuerst begegnen werden, denn hier leben Identitätsprüfungen. Dieses Kapitel zeigt, wie Sie Ihren bestehenden Ablauf betrachten, entscheiden, welche Schritte die Wallet ersetzen könnte, und neu gestalten, ohne die Reise für alle zu stören, die keine Wallet haben.

Schritt eins: Erfassen Sie, was Sie heute abfragen

Was Sie nicht gezeichnet haben, können Sie nicht verbessern. Notieren Sie für jede Stelle der Kundenreise, an der Sie jemanden etwas belegen lassen, vier Dinge:

- **Was Sie verlangen** (das Dokument, das Feld, das Foto).
- **Warum Sie fragen** (eine Rechtspflicht, eine Vertragsklausel, eine Betrugskontrolle, Gewohnheit).
- **Was Sie damit tun** (prüfen und verwerfen, speichern, an einen Partner weitergeben).
- **Was geschieht, wenn die Kundin es nicht beibringen kann** (ablehnen, manuelle Prüfung, Alternative).

Die Liste von Adria Drive überraschte Marta, als sie sie aufschrieb. Sie sammelte einen Reisepassscan, einen Führerscheinscan, ein Selfie und eine Rechnungsadresse. Alle vier speicherte sie „für den Fall der Fälle“ über das

ganze Mietjahr. Nur bei zweien gab es einen klaren Grund. Allein das rechtfertigte die Übung. Anhang A ist eine leere Fassung zum Ausfüllen.

Schritt zwei: Ordnen Sie jede Prüfung einem Fragetyp zu

Einmal erfasst, fällt fast jede Prüfung in einen von fünf Typen. Der Typ zeigt, wie die Wallet helfen könnte.

Fragetyp	Beispiel	Eignung der Wallet
Identitätsabgleich	„Ist das die Person, die in der Buchung steht?“	Stark: PID plus Bindung an die Inhaberin
Altersschwelle	„Ist sie über 18, über 21?“	Sehr stark: eine Ja/Nein-Antwort braucht kein Geburtsdatum
Berechtigung	„Darf sie diese Fahrzeugklasse fahren?“	Stark, wo eine Bescheinigung existiert, etwa ein Führerscheinnachweis
Adresse oder Wohnsitz	„Wohnt sie in dem Land, das wir bedienen?“	Unterschiedlich: hängt davon ab, ob Adressattribute verfügbar und verlässlich sind
Beziehung oder Status	„Ist sie Studentin, Mitglied, Angestellte?“	Hängt davon ab, ob ein Aussteller einen Nachweis anbietet

Sie werden feststellen, dass viele Prüfungen die **Identität** gar nicht brauchen. Sie brauchen eine Tatsache. Hier hilft die Wallet am meisten, und hier beginnen die Datenschutzregeln des nächsten Kapitels zu greifen.

Schritt drei: Entscheiden Sie, wie weit Sie dem Nachweis vertrauen

Legen Sie für jeden Ablauf das **Sicherheitsniveau** fest, das Sie brauchen. Eine Newsletter-Anmeldung braucht keines. Eine Fahrradmiete braucht etwas. Eine regulierte Kontoeröffnung braucht womöglich das höchste Niveau, das Ihre Branchenregeln erlauben. Das Wallet-Rahmenwerk lässt zu, dass Nachweise auf verschiedenen Sicherheitsniveaus vorgelegt werden, und Ihre Risikoentscheidung sollte Ihrer tatsächlichen Gefährdung entsprechen, nicht der beeindruckendsten Einstellung.

Drei Fragen helfen:

1. **Was ist der schlimmste realistische Schaden**, wenn jemand dabei lügt? Geld, Sicherheit, Haftung?
2. **Was prüfen wir sonst noch** drumherum? Zahlungsmittel, Gerät, Verhalten, eine Unterschrift bei der Übergabe?
3. **Schreibt eine Aufsichtsbehörde oder ein Partner das Niveau vor** (ein Kartensystem, eine Bank, ein Versicherer)? Wenn ja, gilt deren Regel.

Schritt vier: Gestalten Sie die Reise mit einer Wallet-Option, nicht mit einer Wallet-Pflicht

Der häufigste Fehler ist, die Wallet als neue Haustür zu behandeln. Das ist sie nicht, und auf Jahre wird sie es nicht sein. Gestalten Sie die Wallet als **Überholspur** und behalten Sie den bestehenden Weg als echte Alternative.

Eine Wallet-Überholspur neben dem bestehenden Weg, damit niemand abgewiesen wird

Ein guter Wallet-fähiger Ablauf hat vier Teile:

1. **Eine klare Wahl am Identitätsschritt.** „Aus Ihrer Wallet teilen“ neben „Dokument hochladen“. Beides sichtbar, nichts versteckt.
2. **Eine kurze, ehrliche Erläuterung**, was abgefragt wird und warum, angezeigt bevor sich die Wallet öffnet. Anhang D enthält Formulierungen.
3. **Eine schnelle Bestätigung** nach der Antwort der Wallet, die der Kundin zeigt, was Sie erhalten haben, statt eines Ladekreisels.
4. **Eine saubere Rückfalloption**, die den Fortschritt der Kundin nicht verliert, wenn die Wallet scheitert.

Für ein Übergabe-Geschäft wie Adria Drive gibt es einen fünften Teil: den **Schalter oder Kiosk**. Eine Kundin kann die Wallet persönlich vorzeigen, durch Antippen oder Scannen, und das Gerät der Mitarbeiterin erhält nur Gültigkeit und Klasse des Führerscheins. Kein Foto, kein Abtippen, keine Kopie. Die Schlange wird kürzer, und am Ende des Tages liegt nichts auf einem gemeinsam genutzten Tablet.

Beispiel: drei fiktive Unternehmen, drei Gestaltungen

Adria Drive (Autovermietung). Fragt die Wallet nach: Gültigkeit und Klassen des Führerscheins und Übereinstimmung zwischen Führerscheininhaber und Buchungsname. Fragt nicht nach Adresse, Dokumentennummer oder Geburtsort. Hält fest, dass die Prüfung bestanden wurde, mit Datum, Ergebnis und Aussteller, nicht das Dokument selbst.

Fenix Fitness (Verkauf mit Altersgrenze). Fragt nur: „Über 18: ja oder nein." Behält nichts außer dem Ja/Nein und der Uhrzeit. Hat keine Geburtsdaten in der Datenbank und damit bei einem Datenleck nichts zu verlieren.

Klarheit Energie (ein regulierter Energieversorger). Gehört zu den Sektoren, in denen Akzeptanz verpflichtend werden kann. Behandelt die Wallet als verpflichtende Option, baut von Anfang an gegen die registrierte beabsichtigte Verwendung und behält seinen bestehenden Dokumentenweg für Kundschaft ohne Wallet, weil seine Aufsichtsbehörde das verlangt.

Alle drei nutzten dieselbe Wallet. Sie stellten unterschiedliche Fragen, speicherten unterschiedliche Dinge und trugen unterschiedliche Pflichten. Das ist der Punkt: **Die Wallet ist ein Kanal, und Ihre Gestaltung entscheidet, was hindurchfließt.**

Fallstricke, die immer wiederkehren

- **Den Papierprozess nachbauen.** Die Wallet nach jedem Feld fragen, das der Scan zeigte. Damit verfehlen Sie den Nutzen.
- **Die Alternative verstecken.** Die Wallet zur einzigen sichtbaren Wahl machen und dann feststellen, dass Kundschaft ohne Wallet abspringt.
- **Das zweite Gerät vergessen.** Ein Ablauf, der die Wallet auf demselben Telefon wie den Browser öffnet, funktioniert anders als einer am Desktop mit einem Telefon in der Nähe. Testen Sie beides.
- **Den Menschen am Schalter ignorieren.** Mitarbeitende brauchen eine einseitige Anleitung, was auf dem Bildschirm erscheint und was zu tun ist, wenn es nicht erscheint.
- **Das Ergebnis speichern, als wäre es das Dokument.** Halten Sie das *Ergebnis* der Prüfung fest. Bauen Sie nicht den Scan nach, den Sie nicht mehr halten wollten.

> **Die Regel:** Bauen Sie die Wallet als Überholspur neben den bestehenden Weg und fragen Sie nur die Frage, die Sie beantwortet haben müssen.

KAPITEL 4

Datenminimierung und Datenschutz

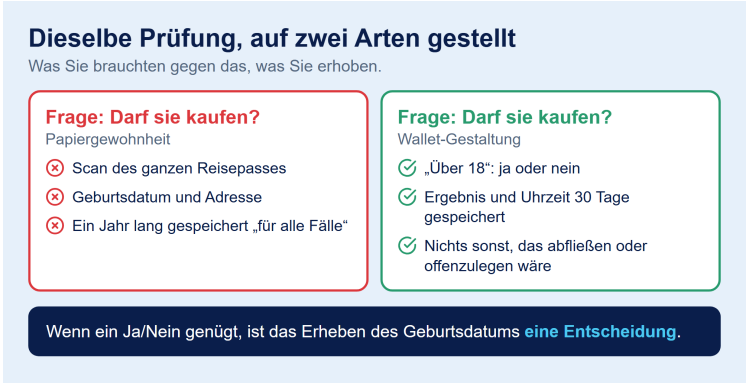
KAPITEL 4
DATENMINIMIERUNG UND DATENSCHUTZ

Jeder Scan, den Sie behalten, ist ein Karton im Regal, den eines Tages jemand öffnen und über den Sie Rechenschaft ablegen sollen

Die Wallet wurde um den Datenschutz herum entworfen. Das klingt für das Unternehmen wie ein Trost, ist aber besser als **Einschränkung** zu verstehen, die Ihnen auferlegt wird. Die Technik macht es leicht, wenig abzufragen. Das Gesetz macht es zur Erwartung. Dieses Kapitel erklärt, was von Ihnen verlangt wird, in der Reihenfolge, in der eine Aufsichtsbehörde fragen würde.

Minimierung ist jetzt ein Gestaltungsmerkmal, kein Schlagwort

Nach der DSGVO dürfen Sie nur personenbezogene Daten verarbeiten, die **dem Zweck angemessen, erheblich und auf das notwendige Maß beschränkt** sind.[5] Jahrelang war dieser Satz schwer durchzusetzen, weil der einzige praktische Weg, ein Alter zu prüfen, der Blick auf ein Dokument war, und ein Geburtsdatum kann man nicht ungesehen machen. Die Wallet ändert die Lage. Ist eine Ja/Nein-Antwort verfügbar, ist das Erheben eines Geburtsdatums keine praktische Notwendigkeit mehr. Es ist eine Entscheidung.



Dieselbe Prüfung, auf zwei Arten gestellt: was Sie brauchten gegen das, was Sie erhoben

Das eIDAS-Rahmenwerk verstärkt dies in seinem eigenen Text. Eine Relying Party darf nicht mehr Daten abfragen, als sie bei der Registrierung angegeben hat, und der angegebene Zweck muss so konkret sein, dass die Abfrage als erforderlich und verhältnismäßig beurteilt werden kann.[3][6] Minimierung wird also doppelt durchgesetzt: durch das Datenschutzrecht und durch das Wallet-Ökosystem selbst.

In der Praxis wenden Sie auf jedes Attribut, das Sie abfragen wollen, einen einfachen Test an:

1. **Benennen Sie den Zweck** in einem Satz („um zu bestätigen, dass der Mieter ein Fahrzeug der Klasse B führen darf“).
2. **Benennen Sie das kleinste Attribut**, das ihm dient („Führerscheinklasse B gültig: ja/nein“, nicht „vollständiger Führerscheindatensatz“).
3. **Fragen Sie, ob eine abgeleitete Antwort möglich ist** („über 21“ statt eines Geburtsdatums).
4. **Schreiben Sie auf, was Sie tun**, wenn die Kundin sich weigert, es zu teilen.

Wenn Sie Schritt eins nicht abschließen können, ist das Attribut nicht erforderlich. Hat Schritt vier keine Antwort, haben Sie einen Ablauf ohne Rückfalloption, und das ist das Problem von Kapitel 7.

Die DSGVO-Pflichten, die mit der Wallet einhergehen

Der Empfang von Daten aus einer Wallet ist weiterhin die Verarbeitung personenbezogener Daten. Nichts an der Technik hebt Ihre Pflichten auf. Ordnen Sie die bekannten Pflichten dem neuen Ablauf zu.

Die DSGVO-Pflichten, die für einen Wallet-Ablauf gelten, und die Frage, die jede an Sie stellt

Rechtsgrundlage (Artikel 6). Wissen Sie, welche Grundlage jede Abfrage trägt: Vertrag, rechtliche Verpflichtung, berechtigtes Interesse oder Einwilligung. Nehmen Sie nicht an, dass Sie eine Einwilligung haben, weil die Kundin „Teilen“ gedrückt hat. Eine Einwilligung muss freiwillig erteilt werden, und sie ist oft nicht die richtige Grundlage für eine Prüfung, die Sie zur Leistungserbringung durchführen müssen.

Transparenz (Artikel 13 und 14). Sagen Sie den Menschen, was Sie abfragen, warum, wie lange Sie das **Ergebnis** aufbewahren und wer es sieht, *bevor* sie in der Wallet zustimmen. Die Wallet zeigt die Anfrage, aber Ihre Information bleibt Ihre Verantwortung.

Datenschutz durch Technikgestaltung und durch datenschutzfreundliche Voreinstellungen (Artikel 25). Das stärkste Argument für Ihre Konformität ist ein Ablauf, der so gebaut wurde, dass er wenig abfragt und noch weniger behält. Das schwächste ist ein Ablauf, der alles erhob und später einen Löschjob hinzufügte.

Speicherbegrenzung (Artikel 5 Absatz 1 Buchstabe e). Legen Sie schriftlich fest, wie lange das **Ergebnis** einer Prüfung aufbewahrt wird, und löschen Sie entsprechend. Wird die Wallet-Antwort nach der Prüfung nicht mehr gebraucht, behalten Sie sie nicht.

Sicherheit (Artikel 32). Die Antwort enthält personenbezogene Daten auf dem Transportweg und, wenn Sie sie protokollieren, im Ruhezustand. Halten Sie sie aus normalen Anwendungsprotokollen, Analysewerkzeugen und Support-Tickets heraus.

Auftragsverarbeiter und Drittlandübermittlungen (Artikel 28 und 44 ff.). Wenn ein Identitätsanbieter, Integrator oder Hosting-Dienst Wallet-Antworten für Sie verarbeitet, brauchen Sie einen Auftragsverarbeitungsvertrag und ein Verständnis davon, wohin die Daten gehen. „Der Anbieter ist europäisch" ist eine Behauptung, die zu prüfen ist, keine Tatsache, die man unterstellt.

Datenschutz-Folgenabschätzung (Artikel 35). Umfangreiche Verarbeitung von Identitätsdaten oder neuartige Technik, deren Einsatz Menschen erheblich betreffen kann, kann eine Folgenabschätzung erfordern. Auch wo sie nicht streng vorgeschrieben ist, ist ein kurzes Papier der beste Weg zu belegen, dass Sie nachgedacht haben. Anhang B enthält ein Register der Datenabfragen, das den Kern einer solchen Abschätzung bildet.

Was die Wallet Ihnen bietet, das Sie nutzen können

Einige der eigenen Schutzmechanismen der Wallet sollten Sie kennen, weil sie prägen, was Ihre Kundschaft erwartet.

- **Die Person sieht, was abgefragt wird, und entscheidet, was sie teilt.** Ihr wird gezeigt, wer fragt und, soweit Registrierungsdaten verfügbar sind, was der registrierte Zweck ist.
- **Pseudonyme.** Eine Person kann in geeigneten Fällen für Dienste, die ihren echten Namen nicht brauchen, ein Pseudonym verwenden.[1]
- **Ein Dashboard.** Wallets sollen Nutzenden erlauben, ihren Verlauf des Teilens einzusehen und eine Relying Party, die zu viel verlangt, bei der Datenschutzbehörde zu melden.[1]
- **Kein Tracking durch den Anbieter.** Der Wallet-Anbieter soll nicht erfahren, wo die Nutzerin Nachweise teilt.

Die letzten beiden betreffen Sie unmittelbar. Eine Kundin, die sich übermäßig befragt fühlt, kann sich mit wenigen Fingertipps beschweren. Ein Unternehmen, das mehr abfragt als angegeben, bricht nicht nur eine Regel; es gibt der Kundin die Mittel, es zu beweisen.

Besondere Kategorien und die biometrische Frage

Zwei Dinge verlangen besondere Sorgfalt.

Biometrie. Die Wallet selbst lässt sich mit Fingerabdruck oder Gesicht entsperren. Dieser Abgleich findet auf dem Gerät der Person statt und wird nicht mit Ihnen geteilt. Führen **Sie** selbst einen Gesichtsabgleich durch, etwa den eines Selfies mit einem Porträtattribut des Nachweises, verarbeiten Sie biometrische Daten. Dienen sie der eindeutigen Identifizierung, sind sie nach

Artikel 9 Daten besonderer Kategorien, die eine eigene Rechtsgrundlage und starke Begründung brauchen.[5] Entscheiden Sie, ob Sie das überhaupt brauchen. In vielen Wallet-Abläufen leistet die kryptografische Bindung an die Inhaberin die Arbeit, die früher ein Selfie leistete.

Sensible Attribute. Manche Nachweise, etwa gesundheits- oder behinderungsbezogene, sind von Natur aus Daten besonderer Kategorien. Wenn Ihr Unternehmen keine klare Rechtsgrundlage für deren Empfang hat, fragen Sie sie nicht ab, und gestalten Sie Ihre Abfrageformulare so, dass niemand in Ihrem Team sie beiläufig hinzufügen kann.

Eine Datenschutzinformation, die Kundschaft tatsächlich liest

Anhang D gibt ein Muster. Die Prinzipien:

- **Sagen Sie in einfachen Worten, was Sie abfragen**, bevor sich die Wallet öffnet.
- **Sagen Sie, was Sie behalten**, und wie lange.
- **Sagen Sie, was passiert, wenn sie ablehnen**, und zeigen Sie die Alternative.
- **Halten Sie es auf dem Bildschirm kurz**, an dem die Entscheidung fällt, mit den Einzelheiten einen Fingertipp entfernt.

> **Die Regel:** Fragen Sie das kleinste Attribut ab, das die Frage beantwortet, behalten Sie nur das Ergebnis und sagen Sie der Kundin beides, bevor sie zustimmt.

KAPITEL 5

Registrierung als Relying Party

Ein Register ist eine gewöhnliche, unglamouröse Liste. Richtig darin zu stehen, lässt den Rest des Systems Ihnen vertrauen

Jedes Unternehmen, das Daten aus einer Wallet abfragen will, soll sich in dem Mitgliedstaat seiner Niederlassung als Relying Party **registrieren**.[3] Dieses Kapitel überspringen die meisten Unternehmen gern, und es entscheidet im Stillen, ob der Rest funktioniert.

Wozu die Registrierung dient

Die Registrierung gibt es, damit eine Wallet der Nutzerin zeigen kann, *wer fragt und wofür*, und damit Aufsichtsbehörden prüfen können, dass das Abgefragte zum Angegebenen passt. Sie macht aus „eine Website hat meine Daten abgefragt“ ein „ein benanntes, registriertes Unternehmen hat diese Attribute für diesen erklärten Zweck abgefragt“. So hält das Ökosystem sein Versprechen, dass Menschen die Kontrolle behalten.

Wo sie gilt, sind die wichtigsten Pflichten diese, wie sie in den Durchführungsvorschriften der Kommission und der geänderten Verordnung erscheinen:

- **Registrieren** im Mitgliedstaat der Niederlassung, mit Identifizierung Ihrer Organisation.[3]
- **Die beabsichtigte Verwendung angeben**, das heißt, die Leistungen, die Sie mit der Wallet erbringen werden, und den Zweck jeder Abfrage.
- **Die genaue Liste der Attribute angeben**, die Sie für jede beabsichtigte Verwendung abfragen wollen.[3]

- **Nichts über das Angegebene hinaus abfragen.** Die Abfrage nicht angegebener Daten wird als Grund für die Aufhebung der Registrierung beschrieben.[3]
- **Ihren Eintrag richtig halten**, was einschließt, ihn zu aktualisieren, wenn sich Ihre Nutzung ändert, und ihn zurückzuziehen, wenn Sie aufhören.

Die Registrierung kann über ein automatisiertes Verfahren im nationalen System erfolgen. Die Mitgliedstaaten sollen ihre Register etwa zu dem Zeitpunkt in Betrieb haben, zu dem Wallets verfügbar werden, aber der praktische Stand wird sich nach Land und Monat unterscheiden.[2]

Das Registrierungspaket: was Sie vorbereiten sollten

Ein Formular füllt man am Tag selbst nicht gut aus. Bereiten Sie zuerst diese Teile vor. Anhang C ist ein Arbeitsblatt, das sie sammelt.

Die sechs Teile eines Registrierungspakets, zusammengestellt, bevor das Formular geöffnet wird

1. **Rechtliche Identität.** Ihr eingetragener Name, Ihre Nummer, Adresse und der Mitgliedstaat der Niederlassung. Wenn Sie in mehreren tätig sind, entscheiden Sie, wo Ihre Hauptniederlassung liegt, und klären Sie die Regel mit Ihrer Beratung.
2. **Eine benannte verantwortliche Kontaktperson.** Jemand, der Mitteilungen erhält und den Eintrag aktuell hält.
3. **Beabsichtigte Verwendungen, eine nach der anderen.** Nicht „Kundenprüfung“, sondern „Altersprüfung an der Kasse für beschränkte Waren“ und „Führerscheinprüfung bei der Fahrzeugübergabe“. Konkret ist besser, denn konkret ist, was eine Prüferin genehmigen kann.

4. **Für jede Verwendung die Attributliste.** Die genauen Attribute, aus Ihrem Test in Kapitel 4. Denken Sie daran: Alles, was Sie je abfragen werden, muss vorher auf der Liste stehen.
5. **Die Begründung.** Ein oder zwei Sätze je Attribut, warum es erforderlich und verhältnismäßig ist. Der Europäische Datenschutzbeauftragte hat betont, dass Beschreibungen der beabsichtigten Verwendung konkret genug sein müssen, damit sich prüfen lässt, ob die abgefragten Attribute erforderlich sind.[6]
6. **Ihre Datenschutzinformation.** Der Link zur Information, die die Kundschaft sieht, und der Kontakt für Datenschutzfragen.

Drei Registrierungsfehler, die Sie vermeiden sollten

Eine lange, großzügige Liste „zur Sicherheit" registrieren. Breite Berechtigungen im Voraus zu verlangen wirkt vorsichtig. Es wirkt auch wie genau die Übererhebung, die die Regeln verhindern sollen, und provoziert Fragen. Registrieren Sie, was Sie tatsächlich nutzen. Aktualisieren Sie, wenn sich das ändert.

Einmal registrieren und vergessen. Eine neue Funktion, die ein zusätzliches Attribut abfragt und ohne Aktualisierung des Registers ausgeliefert wird, ist die Abfrage nicht angegebener Daten. Koppeln Sie Registrierungsänderungen an Ihren Release-Prozess, wie Kapitel 6 zeigt.

Die Registrierung als Aufgabe des Anbieters behandeln. Wenn ein Integrator oder Identitätsanbieter in Ihrem Namen Wallet-Daten abfragt: Wessen Registrierung ist es, und wessen Name sieht die Kundin? Klären Sie das schriftlich. Verantwortung wandert nicht mit dem Vertrag, wenn der Vertrag es nicht sagt.

Registrierungszertifikate und was die Wallet anzeigt

Neben der Registrierung beschreibt das Rahmenwerk ein **Registrierungszertifikat**, ein signiertes Datenobjekt, das Wallets mitteilt, was eine bestimmte Relying Party registriert hat abzufragen.[3] Eine Wallet kann es nutzen, um das, was Sie abfragen, mit dem zu vergleichen, was Sie angegeben haben, und die Nutzerin zu warnen, wenn beides abweicht. Ob Zertifikate ausgestellt werden und in welcher Form, hängt vom Mitgliedstaat ab; bauen Sie also kein Design, das den einen oder anderen Fall voraussetzt. Bauen Sie stattdessen die Disziplin auf: Ihre Anfragen sollten immer Ihrer Angabe entsprechen, mit oder ohne Zertifikat.

Ein weiteres Authentifizierungselement sollten Sie kennen. Wenn Ihr System mit einer Wallet spricht, weist es sich mit Ihnen ausgestellten Zugangsdaten aus, oft **Zugangszertifikate** genannt, damit die Wallet prüfen kann, dass Sie es wirklich sind. Bei einer Eigenentwicklung verwalten Sie sie selbst. Bei einer zugekauften Integration übernimmt das meist Ihr Anbieter, und Sie sollten wissen, auf wessen Namen sie lauten.

Den Eintrag lebendig halten

Registrierung ist ein lebendiger Datensatz, keine Urkunde an der Wand. Eine solide Routine ist klein:

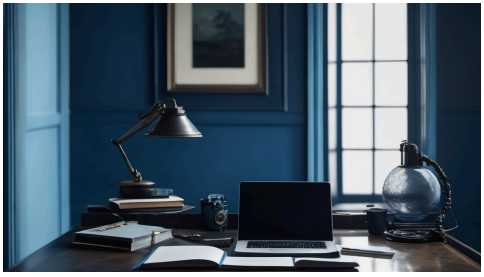
- **Eine benannte Verantwortliche** für den Eintrag.
- **Eine vierteljährliche Überprüfung**, die das Register mit dem Register der Datenabfragen in Anhang B vergleicht.
- **Eine Änderungsregel:** Kein Release, das Wallet-Abfragen hinzufügt, entfernt oder ändert, wird ohne Registrierungsprüfung ausgeliefert.
- **Eine Rückzugsregel:** Wird eine Verwendung eingestellt, wird der Eintrag aktualisiert.

Und ein Hinweis zum Zeitpunkt. Die detaillierten Regeln zur Registrierung waren während der Vorbereitung dieses Buches Gegenstand von Änderungen und Entwürfen, und der Geltungsbeginn einiger Bestimmungen wird von verschiedenen Quellen unterschiedlich angegeben.[3] Behandeln Sie jedes Datum in diesem Kapitel als Hinweis zum Nachprüfen, nicht als Tatsache, um die herum Sie planen.

> **Die Regel:** Registrieren Sie genau das, was Sie abfragen, nicht mehr, und machen Sie eine Registrierungsprüfung zum Teil jeder Änderung Ihrer Wallet-Abfragen.

KAPITEL 6

Wallet-basierte Prüfung integrieren



Integration ist überwiegend gewöhnliche Produktarbeit: eine Anfrage, eine Antwort, eine Entscheidung und ein Eintrag

Dieses Kapitel richtet sich an die Person, die die Integration verantworten wird, technisch oder nicht. Es erklärt die Form des Ablaufs, Ihre drei realistischen Wege und die Fragen, die Sie davor bewahren, das Falsche zu kaufen oder zu bauen. Es hört bewusst vor dem Code auf, weil die Spezifikationen sich noch bewegen und hier gedruckter Code schnell veralten würde.

Der Ablauf im Überblick

Was auch immer Sie wählen, die Abfolge ist dieselbe.

Die sechs Momente einer Wallet-Prüfung, von Ihrer Anfrage bis zu Ihrem festgehaltenen Ergebnis

1. **Ihr Dienst erstellt eine Anfrage.** Sie nennt, welche Attribute Sie wollen, aus welcher Art Nachweis, mit einem Einmalwert, damit die Antwort später nicht wiederverwendet werden kann.
2. **Die Wallet der Kundin empfängt sie.** Auf demselben Telefon über einen Link oder Button. Am Desktop meist über einen QR-Code, den die Kundin mit dem Telefon scannt. Am Schalter durch Antippen oder Scannen.
3. **Die Wallet zeigt der Kundin**, wer fragt und was angefragt wird, und bittet um Zustimmung durch Entsperren des Geräts.
4. **Die Wallet liefert eine Präsentation.** Die Antwort enthält die signierten Daten und den Beweis, dass sie der Inhaberin gehören.
5. **Ihr Dienst prüft sie.** Signatur, vertrauenswürdiger Aussteller, Gültigkeit, Bindung an die Anfrage, Status.
6. **Sie entscheiden und halten fest.** Bestanden, nicht bestanden oder an einen Menschen verweisen. Behalten Sie das Ergebnis, nicht die Rohantwort, sofern keine Regel anderes verlangt.

Die Protokolle hinter den Schritten eins bis vier sind offene Standards der OpenID Foundation: einer für das **Ausstellen** von Nachweisen in eine Wallet und einer für das **Vorlegen** gegenüber einer Relying Party.[4] Daneben legt das Rahmenwerk zwei Nachweisformate und ein Sicherheitsprofil fest, damit

Implementierungen zusammenarbeiten. Sie werden die Namen hören. Ihre Aufgabe ist, Ihren Anbieter oder Ihr Team zu fragen, welche Versionen sie unterstützen und ob sie gegen die europäische Referenzimplementierung und aktuelle Interoperabilitätsveranstaltungen getestet haben, nicht sie auswendig zu lernen.

Dasselbe Gerät oder ein anderes?

Ein Detail, das die meisten frühen Enttäuschungen auslöst. Eine Kundin im Telefonbrowser wechselt in die Wallet-App und zurück. Eine Kundin am Laptop scannt einen Code mit dem Telefon. Eine Kundin im Laden tippt an. Jeder Weg hat eigene Schwachstellen: eine App, die sich nicht öffnet, ein Code, der abläuft, ein Browser, der den Zustand verliert, wenn die Wallet-App übernimmt. Bauen und testen Sie alle drei, mit echten Wallets und echten Geräten, und bewahren Sie den Fortschritt der Kundin, wenn sie weggeht und wiederkommt.

Ihre drei Wege

Drei Wege in die Wallet-Prüfung und wer in welchem welche Verantwortung trägt

Weg A: Über Ihren bestehenden Identitätsanbieter anbinden. Wenn Sie schon einen Anbieter für Identitätsprüfung oder Authentifizierung nutzen, fragen Sie nach seiner Wallet-Roadmap. Der Vorteil sind Tempo und ein Vertrag. Die Risiken sind Abhängigkeit von seinem Zeitplan, geringere Einsicht in die Details und die Registrierungs- und Verantwortungsfragen aus Kapitel 5.

Weg B: Einen spezialisierten Wallet-Prüfdienst nutzen. Ein Anbieter, der dafür da ist, die empfangende Seite der Wallet für Sie zu übernehmen: Er erstellt Anfragen, prüft Präsentationen und gibt ein sauberes Ergebnis

zurück. Sie schreiben eine kleine Integration und behalten einen klaren Vertrag. Vergleichen Sie sie wie jeden Auftragsverarbeiter: wo Daten verarbeitet werden, was aufbewahrt wird, welche Zertifizierungen bestehen und was passiert, wenn sich die Spezifikationen ändern.

Weg C: Selbst bauen. Angemessen, wenn Identität zum Kern Ihres Produkts gehört und Sie Sicherheitsingenieure haben. Sie gewinnen Kontrolle und tragen die volle Last: Spezifikationen verfolgen, Zertifikate pflegen, Vertrauenslisten verwalten, Statusprüfungen handhaben, interoperabel bleiben und Sicherheitsprüfungen bestehen. Wenige kleine Unternehmen sollten das für einen ersten Start wählen.

Die meisten Lesenden sollten für eine erste Version A oder B wählen, das Design modular halten und später neu bewerten. „Modular" heißt: eine Stelle in Ihrem Code, an der ein Wallet-Ergebnis zu Ja, Nein oder „an einen Menschen verweisen" wird, sodass ein Anbieterwechsel nicht heißt, Ihr Produkt zu ändern.

Zwölf Fragen an jeden Anbieter

Legen Sie sie schriftlich vor, bevor Sie unterschreiben. Ein guter Anbieter beantwortet sie klar.

1. Welche Wallets und Nachweisformate unterstützen Sie heute, und welche stehen mit Terminen auf der Roadmap?
2. Haben Sie gegen die EU-Referenzimplementierung und aktuelle Interoperabilitätsveranstaltungen getestet? Zeigen Sie Ergebnisse.
3. Wessen Name und welche Zertifikate erscheinen der Wallet, wenn eine Anfrage gestellt wird?
4. Wer registriert sich als Relying Party, und wer hält den Eintrag richtig?
5. Wo werden Wallet-Antwortdaten verarbeitet und gespeichert, und wie lange?
6. Können wir Attribute einzeln abfragen und je Verwendung das Minimum festlegen, das wir brauchen?
7. Welche Vertrauenslisten prüfen Sie, und wie schnell übernehmen Sie Änderungen?
8. Wie gehen Sie mit widerrufenen oder ausgesetzten Nachweisen um?
9. Was erhalten wir: Rohdaten, ein signiertes Ergebnis oder nur bestanden/nicht bestanden?
0. Wie sieht Ihr Vorfallprozess aus, wenn ein Spezifikationsfehler oder ein Zertifikatsproblem entdeckt wird?
1. Welche Verfügbarkeit sagen Sie zu, und wie verhält sich der Dienst im Fehlerfall?

2. Was geschieht mit unseren Daten und unserer Integration, wenn der Vertrag endet?

Sicherheit in je einem Satz

- **Verwenden Sie in jeder Anfrage einen frischen Einmalwert** und weisen Sie Antworten zurück, die nicht dazu passen.
- **Halten Sie Wallet-Antworten aus Protokollen, Analysen, Fehler-Trackern und Support-Werkzeugen heraus.**
- **Prüfen Sie auf dem Server**, nie nur im Browser.
- **Schützen Sie Ihre eigenen Zertifikate und Schlüssel** als Produktionsgeheimnisse, mit Rotation und Ablaufwarnungen.
- **Begrenzen und überwachen Sie** den Endpunkt wie jeden Identitätsendpunkt.
- **Halten Sie Ergebnisse mit genug Kontext fest** (Zeit, Ablauf, Ergebnis, Aussteller), um nachzuforschen, und mit nicht mehr.

Testen wie ein Unternehmen, nicht wie ein Labor

Testen Sie mit **echten Menschen auf echten Telefonen**, auch auf älteren Geräten und mit der am wenigsten technikaffinen Person Ihres Teams. Zählen Sie, wie viele ohne Hilfe ans Ziel kommen. Messen Sie die Zeit gegen den alten Prozess. Achten Sie darauf, was Kundinnen laut sagen, wenn sich die Wallet öffnet. Diese Beobachtungen sind mehr wert als jede Spezifikations-Checkliste, und sie sind der Beleg, den Sie wollen, wenn Sie über die Ausweitung entscheiden.

> **Die Regel:** Halten Sie die Wallet hinter einer einzigen Entscheidungsstelle in Ihrem Produkt, wählen Sie den leichtesten Weg, der Ihr Risiko trägt, und testen Sie mit echten Kundinnen auf echten Telefonen.

KAPITEL 7

Wenn etwas schiefgeht

Ein leeres Telefon am Schalter ist kein Randfall. Es ist Dienstag

Ein Wallet-Ablauf, der für die kooperative Kundin auf einem neuen Telefon funktioniert, ist eine Demo. Ein Ablauf, der alles andere übersteht, ist ein Dienst. Dieses Kapitel listet auf, wie Dinge scheitern und was ein vorbereitetes Unternehmen jeweils tut.

Die sechs Fehlerfälle, denen Sie begegnen werden

Die sechs häufigsten Fehlerfälle und die Reaktion, die Kundin und Kontrolle erhält

1. Die Kundin hat keine Wallet. Die meisten Kundinnen und Kunden werden das für einige Zeit nicht haben. Das ist kein Versagen der Kundin. Ihr alternativer Weg ist Teil des Produkts, mit derselben Klarheit, Geschwindigkeit und demselben Ton wie der Wallet-Weg. Lassen Sie Menschen nicht fühlen, sie würden dafür bestraft, Papier zu nutzen.

2. Die Wallet wird nicht unterstützt. Die Wallet einer Kundin kann aus einem anderen Land stammen, eine neuere Version nutzen oder auf einem älteren Telefon scheitern. Zeigen Sie eine klare Meldung, bieten Sie sofort den alternativen Weg an und **protokollieren Sie den Fehler**, damit Sie Muster erkennen.

3. Die Prüfung scheitert. Ein Nachweis ist abgelaufen, widerrufen oder stammt von einem Aussteller, dem Sie nicht vertrauen, oder der Name passt nicht zur Buchung. Sagen Sie klar, was gescheitert ist, in Worten, mit denen die Kundin handeln kann („dieser Führerschein ist abgelaufen"), ohne mehr Daten offenzulegen als nötig. Bieten Sie die Weiterleitung an einen Menschen an, keine Sackgasse.

4. Das Gerät der Kundin ist verloren, kaputt oder leer. Ein Wiederherstellungsproblem an Ihren Helpdesk weiterzureichen, ist üblich. Bereiten Sie ein Skript vor: was die Person tun kann, was Sie als alternativen Beleg akzeptieren können und was nicht. Es gilt die vorsichtige Regel jedes Kontowiederherstellungsprozesses: **Lassen Sie Ihre Rückfalloption nicht schwächer sein als die Kontrolle, die sie ersetzt.**

5. Betrug. Wallets erschweren manchen Betrug und verlagern den Rest. Rechnen Sie mit geliehenen Geräten, genötigten Nutzenden, gefälschten Relying-Party-Aufforderungen und Versuchen, Ihre Mitarbeitenden zu überreden, die Prüfung „nur dieses eine Mal" zu überspringen. Schulen Sie die Mitarbeitenden: Der Ausnahmeweg ist der Ort, an den Angreifer gehen. Führen Sie Protokoll über Übersteuerungen und überprüfen Sie sie.

6. In Ihrem eigenen System bricht etwas. Ein Update der Vertrauensliste schlägt fehl, ein Zertifikat läuft ab, eine Bibliothek ändert sich. Überwachen Sie die Prüfung als Dienst, mit Alarmen und einem Menschen, der den nächsten Schritt kennt.

Barrierefreiheit gehört zur Prüfung

Ein Wallet-Ablauf, den ein Mensch mit eingeschränktem Sehvermögen, begrenzter Fingerfertigkeit oder Hörbeeinträchtigung nicht nutzen kann, ist kein schnellerer Weg. Es ist eine Barriere mit schönerem Logo. Der Europäische Rechtsakt zur Barrierefreiheit setzt inzwischen Pflichten für viele verbrauchernahe digitale Dienste, und das eigene Design der Wallet zielt

auf Barrierefreiheit. Prüfen Sie Ihre eigenen Bildschirme, Aufforderungen, Zeitlimits und Fehlermeldungen mit assistiven Technologien und testen Sie mit Menschen, die sie nutzen. Halten Sie einen begleiteten Weg bereit, der gar nicht von einem Smartphone abhängt.

Support: das Skript hinter dem Bildschirm

Geben Sie Ihrem Support-Team drei einseitige Werkzeuge:

- **Was die Kundin bei jedem Schritt sieht**, mit Screenshots.
- **Die vier häufigsten Probleme** und die genaue Antwort auf jedes.
- **Was sie nicht tun dürfen**: ein per Chat geschicktes Foto statt einer Prüfung akzeptieren, eine gescheiterte Prüfung umgehen, weil die Kundin verärgert ist, oder die Kundin bitten, Daten vorzulesen, die die Wallet hätte senden sollen.

Betroffenenanfragen und Vorfälle

Behandeln Sie Wallet-Daten wie alle anderen personenbezogenen Daten in Ihren Prozessen für **Auskunft, Berichtigung und Löschung**. Die sauberste Antwort auf eine Anfrage ist ein kurzer Eintrag: das Ergebnis, das Datum und der Ablauf. Wenn Sie mehr behalten haben, haben Sie mehr offenzulegen, zu schützen und zu erklären.

Wenn Sie vermuten, dass Wallet-Antworten durch ein Protokoll, eine fehlerhafte Integration oder einen Anbieterfehler abgeflossen sind, führen Sie Ihren normalen Verletzungsprozess durch: eindämmen, bewerten und innerhalb der 72-Stunden-Frist entscheiden, ob die Behörde informiert werden muss. Üben Sie die erste Stunde, bevor Sie sie brauchen.

Messen, worauf es ankommt

Vier Zahlen sagen das Meiste von dem, was Sie wissen müssen:

- **Abschlussquote** auf dem Wallet-Weg gegenüber dem alten Weg.
- **Zeit bis zum Abschluss** je Weg.
- **Rückfallquote**, also wie viele Wallet-Versuche im alternativen Weg enden.
- **Quote manueller Prüfungen** und die Gründe.

Ist der Abschluss höher und der Rückfall niedrig, hilft die Wallet. Ist der Rückfall hoch, liegt das Problem meist am Ablauf, nicht an der Kundin.

Die Regel: Jeder Wallet-Schritt braucht eine sichere, gleichermaßen respektvolle Alternative, und Ihre Rückfalloption darf nie schwächer sein als die Kontrolle, die sie ersetzt.

KAPITEL 8

Ihr 90-Tage-Plan zur Wallet-Bereitschaft

Eine Straße zur blauen Stunde: Sie müssen nicht den ganzen Weg sehen, nur die nächste Ecke

Sie haben die Landkarte. Dieses Kapitel macht daraus neunzig Tage Arbeit in drei Phasen, die aufeinander aufbauen. Der Plan ist bewusst bescheiden. Ein kleines Unternehmen kann ihn neben dem Tagesgeschäft abschließen.

Drei Phasen über neunzig Tage: verstehen, entscheiden, pilotieren

Tag 1 bis 30: Verstehen

Woche 1: Benennen und abgrenzen. Benennen Sie eine Verantwortliche für die Wallet-Bereitschaft. Listen Sie jeden Ablauf auf, in dem Sie Kundinnen und Kunden etwas belegen lassen. Füllen Sie Anhang A aus.

Woche 2: Einordnen und minimieren. Ordnen Sie jeder Prüfung einen Fragetyp zu (Kapitel 3) und wenden Sie den Minimierungstest an (Kapitel 4). Füllen Sie Anhang B aus. Markieren Sie die Prüfungen, bei denen eine Ja/Nein-Antwort genügen würde.

Woche 3: Ihre Pflichten kennen. Entscheiden Sie, in welcher der drei Situationen Sie sind: zur Akzeptanz verpflichtet, wahrscheinlich gefragt oder frei in der Entscheidung. Lassen Sie sich für Abläufe in einem regulierten Sektor beraten. Ermitteln Sie Ihre Aufsichtsbehörde und das nationale Register für den Mitgliedstaat Ihrer Niederlassung.

Woche 4: Anbieter fragen. Senden Sie die zwölf Fragen aus Kapitel 6 an Ihre jetzigen Anbieter für Identität oder Authentifizierung. Halten Sie die Antworten fest, und das Schweigen.

Ergebnis des Monats: ein erfasstes Inventar, ein Register der Datenabfragen und eine schriftliche Einschätzung Ihrer Rechtslage.

Tag 31 bis 60: Entscheiden

Woche 5: Den Pilotablauf wählen. Wählen Sie einen Ablauf, in dem die Wallet klar hilft, mit mäßigem Risiko und guter Rückfalloption. Eine Altersprüfung oder eine Schalterübergabe ist meist besser als eine Kontoeröffnung.

Woche 6: Den Weg wählen. A, B oder C aus Kapitel 6, mit schriftlichen Gründen. Vergleichen Sie zwei Anbieter anhand der zwölf Fragen.

Woche 7: Registrierungspaket und Information entwerfen. Vervollständigen Sie Anhang C. Entwerfen Sie den Kundentext in Anhang D. Erstellen Sie eine kurze Folgenabschätzung auf Basis Ihres Registers.

Woche 8: Rückfalloption und Support-Skript gestalten. Legen Sie fest, was geschieht, wenn die Wallet nicht verfügbar ist oder die Prüfung scheitert. Informieren Sie den Support. Schreiben Sie die einseitige Mitarbeiteranleitung.

Ergebnis des Monats: ein gewählter Pilot, ein gewählter Weg, ein Registrierungsentwurf, eine Information und ein Support-Plan.

Tag 61 bis 90: Pilotieren

Woche 9: Bauen oder konfigurieren. Integrieren Sie in einer Testumgebung. Gehen Sie Anhang E mit Ihrer technischen Leitung durch.

Woche 10: Mit echten Menschen testen. Mindestens zehn Personen, mindestens drei auf älteren Geräten, mindestens eine mit assistiver Technologie. Halten Sie Zeit, Abschluss und Kommentare fest.

Woche 11: Begrenzter Start. Öffnen Sie die Wallet-Option für einen kleinen Teil der Kundschaft oder einen einzelnen Standort. Beobachten Sie täglich die vier Zahlen aus Kapitel 7.

Woche 12: Auswerten und entscheiden. Vergleichen Sie die Ergebnisse mit dem alten Weg. Entscheiden Sie, ob Sie ausweiten, anpassen oder pausieren. Aktualisieren Sie das Register, die Information und den Registrierungseintrag, sodass sie dem entsprechen, was Sie tatsächlich tun.

Ergebnis des Quartals: ein laufender, kleiner, überwachter Pilot und eine Entscheidung auf Basis von Belegen.

Entscheidungen auf dem Weg

Entscheidung	Wer entscheidet	Bis wann
Sind wir zur Akzeptanz der Wallet verpflichtet, und ab wann?	Inhaberin oder Inhaber mit Rechtsberatung	Tag 21
Welchen Ablauf pilotieren?	Produktverantwortliche	Tag 35
Bauen, kaufen oder anbinden?	Produkt und technische Leitung	Tag 45
Was registrieren wir, und wer verantwortet es?	Compliance oder Datenschutzbeauftragte	Tag 55
Was ist die Rückfalloption je Ablauf?	Betrieb	Tag 58
Ausweiten, anpassen oder pausieren?	Inhaberin oder Inhaber	Tag 90

Worauf nach Tag 90 zu achten ist

Das Ökosystem wird sich weiter ändern. Betrauen Sie jemanden damit, vier Dinge zu verfolgen, anfangs monatlich: die **nationale Verfügbarkeit der Wallets** in den Ländern, die Sie bedienen, **Änderungen der Registrierungsregeln**, **Aktualisierungen der technischen Spezifikationen**, auf die sich Ihr Anbieter stützt, und **Hinweise Ihrer Aufsichtsbehörde**. Eine dreißigminütige monatliche Durchsicht genügt, um ein kleines Unternehmen aus Schwierigkeiten herauszuhalten.

> **Die Regel:** Beginnen Sie mit einem Ablauf, lernen Sie von echter Kundschaft und lassen Sie die Belege, nicht die Begeisterung, entscheiden, wie weit Sie gehen.

Schlusswort: Ein besseres Geschäft, sorgfältig gebaut

SCHLUSSWORT
DIE WALLET IM UNTERNEHMEN

Eine offene Tür ist nur eine Einladung. Entscheidend ist, was Sie tun, wenn die Menschen hindurchgehen

Marta hat das Geschäft von Adria Drive nicht um die Wallet herum neu aufgebaut. Sie tat etwas Kleineres und Klügeres. Sie erfasste, was ihr Schalter abfragte, und fand zwei Prüfungen, die sie ohne Grund behielt. Sie schrieb die eine Frage auf, die die Wallet bei der Übergabe beantworten konnte. Sie registrierte diesen Zweck, sagte es den Kundinnen und Kunden klar, hielt den alten Weg offen und maß. In ihrem ersten Testsommer war der Münchner Kunde, der die Frage gestellt hatte, in weniger als zwei Minuten durch den Schalter, und nichts von ihm blieb auf ihrem gemeinsam genutzten Tablet zurück.

Das ist die ganze Strategie in einer Geschichte. Die Wallet ist kein Ereignis, das man überstehen muss, und keine Trophäe zum Sammeln. Sie ist die Chance, eine riskante Gewohnheit, das Sammeln von Bildern von Dokumenten, durch eine bessere zu ersetzen: eine genaue Frage zu stellen und eine genaue, überprüfbare Antwort zu erhalten.

Die Unternehmen, die am meisten profitieren, werden nicht die frühesten oder lautesten sein. Es werden die sein, die:

- **wissen, was sie abfragen und warum**;
- **das Wenigste abfragen, was die Frage beantwortet**;
- **ehrlich registrieren und angeben** und die Angabe wahr halten;
- **einen ebenso guten Weg für Menschen ohne Wallet bereithalten**;

- **die leichteste Integration wählen, die ihr Risiko trägt**; und
- **von echter Kundschaft lernen, bevor sie skalieren.**

Sie müssen nicht heute fertig werden. Sie brauchen eine Liste, eine verantwortliche Person und einen Ablauf. Beginnen Sie mit Anhang A.

ANHANG A

Inventar der Prüfabläufe

Eine Zeile für jede Stelle, an der Sie Kundinnen oder Kunden bitten, zu belegen, wer sie sind oder etwas über sich. Nehmen Sie von Mitarbeitenden bearbeitete Schritte an Schaltern und am Telefon hinzu. Überprüfen Sie das Inventar jedes Quartal. Fragetyp: **I** Identitätsabgleich, **A** Altersschwelle, **B** Berechtigung, **W** Wohnsitz, **S** Status oder Beziehung.

Ablauf / Schritt	Was wir heute abfragen	Warum (Gesetz, Vertrag, Risiko)	Typ	Gespeichert? Wie lange?	Kann die Wallet helfen?

Fragen, die Sie für jede Zeile beantworten sollten

- Welches Gesetz, welcher Partner oder Vertrag verlangt diese Prüfung, falls einer? _____
- Könnte eine Ja/Nein-Antwort oder ein einzelnes Attribut das Dokument ersetzen? Ja / Nein
- Was geschieht heute, wenn die Kundin es nicht beibringen kann? _____
- Wer ist für diese Prüfung verantwortlich? _____

ANHANG B

Register der Datenabfragen

Dies ist die nützlichste Seite des Buches. Sie bildet den Kern Ihrer Folgenabschätzung, Ihrer Datenschutzinformation und Ihres Registrierungseintrags. Halten Sie sie im Einklang mit dem, was Ihr Produkt tatsächlich abfragt.

Beabsichtigte Verwendung	Abgefragtes Attribut	Warum erforderlich (ein Satz)	Rechtsgrundlage	Gespeichert als	Aufbewahrung	Wer sieht es

Der Test für jede Zeile

- ☐ Der Zweck ist in einem Satz benannt.
- ☐ Ein kleineres Attribut oder eine abgeleitete Antwort wurde erwogen.
- ☐ Wir behalten das Ergebnis, nicht die Rohantwort.
- ☐ Die Aufbewahrungsfrist ist festgelegt und die Löschung automatisch.
- ☐ Die Kundin wird informiert, bevor sie zustimmt.
- ☐ Das Attribut steht in unserem Registrierungseintrag.

ANHANG C

Arbeitsblatt zur Registrierung als Relying Party

Füllen Sie es aus, bevor Sie das nationale Registrierungsformular öffnen. Prüfen Sie die aktuellen Anforderungen Ihres Mitgliedstaats der Niederlassung, denn Formulare und Felder unterscheiden sich.

Punkt	Unser Eintrag
Rechtlicher Name und Registernummer	
Mitgliedstaat der Niederlassung	
Eingetragene Anschrift	
Benannte verantwortliche Kontaktperson und Vertretung	
Kontakt für Datenschutz (DSB oder Entsprechung)	
Aufsichtsbehörde	
Link zur Datenschutzinformation für Kundschaft	
Wer die technische Integration betreibt (wir / Anbieter)	
Auf wessen Namen die Zertifikate gegenüber der Wallet lauten	

Beabsichtigte Verwendungen

Verwendung	Leistung, die sie stützt	Attribute (genaue Liste)	Begründung

Vor dem Absenden

- ☐ Jedes Attribut unseres Produkts steht hier, und nichts sonst.
- ☐ Eine benannte Person verantwortet den Eintrag und seine Änderungen.
- ☐ Unser Release-Prozess enthält eine Registrierungsprüfung.
- ☐ Die Verantwortungsverteilung mit einem Anbieter steht im Vertrag.

- [ ] Wir wissen, wie wir den Eintrag aktualisieren oder zurückziehen.

ANHANG D

Formulierungen für die Kundschaft

Passen Sie sie an Ihre eigenen Leistungen, Sprache und Tonalität an. Halten Sie sie kurz, konkret und ehrlich.

Bevor sich die Wallet öffnet

> **Mit Ihrer Wallet bestätigen** Wir bitten Ihre Wallet zu bestätigen, *[dass Sie über 18 sind]*. Wir erhalten *[weder Ihr Geburtsdatum noch Ihre Adresse oder Dokumentennummer]*. Wir speichern *[das Ergebnis und die Uhrzeit]* für *[30 Tage]*. Sie können stattdessen *[ein Dokument hochladen]*.

Wenn die Kundin ablehnt

> **Kein Problem.** Sie können auf andere Weise bestätigen: *[Dokument hochladen / Schalter besuchen / uns kontaktieren]*. Das dauert etwa *[x Minuten]*.

Wenn die Prüfung scheitert

> **Wir konnten das nicht bestätigen.** *[Dieser Führerschein ist abgelaufen.]* Sie können einen anderen Nachweis versuchen oder eine Mitarbeiterin oder einen Mitarbeiter um Hilfe bitten. Wir haben keine der Informationen gespeichert, die Ihre Wallet geteilt hat.

Wenn die Wallet nicht unterstützt wird

> **Ihre Wallet konnte sich nicht verbinden.** Das kann bei manchen Wallets und älteren Telefonen vorkommen. Bitte nutzen Sie stattdessen *[den anderen Weg]*. Ihr Fortschritt ist gespeichert.

Skript für Mitarbeitende am Schalter

- Sagen Sie, was Sie abfragen werden und warum, bevor Sie fragen.
- Sagen Sie der Kundin, was auf Ihrem Bildschirm erscheint.
- Wenn die Prüfung scheitert, nutzen Sie die Weiterleitungsschritte, nicht Ihr eigenes Urteil.
- Akzeptieren Sie nie ein per Chat gesendetes Foto statt der Prüfung.
- Halten Sie jede Ausnahme mit Begründung fest.

ANHANG E

Integrations-Checkliste

Für die technische Leitung und die Produktverantwortliche gemeinsam.

Umfang und Gestaltung

- ☐ Pilotablauf und genaue Attribute stehen fest und entsprechen Anhang B.
- ☐ Die Wallet-Prüfung liegt hinter einer Entscheidungsstelle, die bestanden, nicht bestanden oder Weiterleitung liefert.
- ☐ Der alternative Weg ist gebaut, sichtbar und gleich schnell.
- ☐ Der Fortschritt bleibt erhalten, wenn die Kundin geht und zurückkehrt.

Sicherheit

- ☐ In jeder Anfrage wird ein frischer Einmalwert verwendet und bei der Rückgabe geprüft.
- ☐ Die Prüfung erfolgt auf dem Server.
- ☐ Wallet-Antworten sind aus Protokollen, Analysen und Support-Werkzeugen ausgeschlossen.
- ☐ Zertifikate und Schlüssel werden als Geheimnisse mit Ablaufwarnungen verwaltet.
- ☐ Vertrauenslisten- und Statusprüfungen sind eingerichtet und überwacht.

Tests

- ☐ Getestet auf demselben Gerät, einem zweiten Gerät und persönlich.
- ☐ Getestet auf älteren Geräten und mit assistiver Technologie.
- ☐ Getestet mit abgelaufenen, widerrufenen und nicht vertrauenswürdigen Nachweisen.
- ☐ Getestet, was geschieht, wenn die Wallet mitten im Ablauf abgebrochen wird.

Betrieb

- ☐ Der Support hat die einseitige Anleitung und das Skript für die vier Probleme.
- ☐ Die vier Kennzahlen aus Kapitel 7 stehen auf einem Dashboard.
- ☐ Es gibt einen Vorfallweg für eine abgeflossene Antwort oder ein ausgefallenes Zertifikat.
- ☐ Der Registrierungseintrag entspricht dem laufenden Produkt.

ANHANG F

Tracker für die 90 Tage

Woche	Aufgabe	Verantwortlich	Fällig	Erledigt
1	Verantwortliche benennen; Abläufe auflisten (Anhang A)			
2	Einordnen und minimieren (Anhang B)			
3	Rechtslage und Aufsichtsbehörde klären			
4	Zwölf Anbieterfragen versenden			
5	Pilotablauf wählen			
6	Weg wählen (A, B oder C)			
7	Registrierungspaket und Information; kurze Folgenabschätzung			
8	Rückfalloption und Support-Anleitung			
9	Bauen oder konfigurieren			
10	Mit zehn Personen testen			
11	Begrenzter Start; Zahlen beobachten			
12	Auswerten; ausweiten, anpassen oder pausieren			

Rückblick am Quartalsende

- Abschlussquote Wallet gegenüber altem Weg: _____
- Rückfallquote und Hauptgründe: _____
- Entscheidung (ausweiten / anpassen / pausieren): _____
- Was wir in Register und Registrierungseintrag ändern: _____

Glossar

Attribut. Eine einzelne Tatsache in einem Nachweis, etwa das Geburtsdatum.

Attributsbescheinigung (elektronische Attributsbescheinigung). Eine signierte Aussage eines Ausstellers über eine Person, etwa ein Diplom oder ein Führerschein.

Aussteller. Die Organisation, die einen Nachweis erstellt und signiert.

Beabsichtigte Verwendung. Der bei der Registrierung angegebene Zweck, für den eine Relying Party Wallet-Daten abfragt.

Inhaberin / Inhaber. Die Person, die Nachweise in ihrer Wallet hält.

mdoc. Das Format Mobile Document aus ISO 18013-5, das auch für digitale Führerscheine genutzt wird.

Nachweis (Credential). Ein signierter digitaler Datensatz in einer Wallet, der ein oder mehrere Attribute enthält.

OpenID4VCI / OpenID4VP. Offene Standards zum Ausstellen von Nachweisen in eine Wallet und zum Vorlegen gegenüber einer Relying Party.

PID. Personenidentifizierungsdaten: der Kern-Identitätsdatensatz, ausgestellt unter der Verantwortung eines Mitgliedstaats.

Registrierungszertifikat. Ein signiertes Objekt, das beschreibt, was eine Relying Party registriert hat abzufragen.

Relying Party (vertrauende Beteiligte). Ein Unternehmen oder eine öffentliche Stelle, die bei einer Wallet Daten abfragt, um eine Leistung zu erbringen. Das sind Sie.

SD-JWT. Ein Nachweisformat, das für selektive Offenlegung gebaut wurde.

Selektive Offenlegung. Nur einen Teil eines Nachweises oder eine abgeleitete Antwort teilen, während die Signatur weiter geprüft werden kann.

Starke Nutzerauthentifizierung. Authentifizierung mit mindestens zwei unabhängigen Elementen, die einige Gesetze für einige Sektoren verlangen.

Vertrauensliste. Eine veröffentlichte Liste von Ausstellern und Diensten, die ein Rahmenwerk anerkennt.

Wallet-Anbieter. Die Organisation, die den Nutzenden die Wallet-App bereitstellt.

Zugangszertifikat. Ein einer Relying Party ausgestelltes Zertifikat, damit eine Wallet prüfen kann, dass sie wirklich die ist, die sie vorgibt zu sein.

Ein Hinweis zu GDPRGard.eu

Wenn Ihre Wallet-Arbeit Kundendaten berührt, können die kostenlosen Werkzeuge, Leitfäden und Artikel auf **gdprgard.eu** bei den umgebenden Datenschutzaufgaben helfen: Verzeichnisse von Verarbeitungstätigkeiten, Folgenabschätzungen, Reaktion auf Datenpannen und Datenschutzinformationen. Sie sind eine begleitende Ressource, kein Ersatz für Beratung zu Ihrer eigenen Situation.

Über die Autorin

Zirlandia Milkovic schreibt praktische, verständliche Ratgeber zu Datenschutz, Cybersicherheit, KI und dazu, ein Unternehmen mit Zuversicht aufzubauen. Sie ist überzeugt, dass Technologie kleinen Unternehmen mehr Kontrolle geben sollte, nicht weniger, und dass niemand einen technischen Abschluss braucht, um seine Rechte zu verstehen oder seine Kundschaft zu schützen.

Sie ist Autorin einer Reihe von Business-Ratgebern, darunter *GDPR Made Simple for Women Founders*, und ihre Arbeit konzentriert sich darauf, komplexe Regeln und schnelllebige Technik in einfache Schritte, Checklisten und Vorlagen zu übersetzen, die beschäftigte Menschen tatsächlich nutzen können. Sie steht außerdem hinter **GDPRGard**, einer wachsenden Sammlung kostenloser DSGVO-Werkzeuge, Leitfäden und Artikel für kleine Unternehmen, erhältlich auf gdprgard.eu.

Die Wallet im Unternehmen ist aus einer einfachen Beobachtung entstanden: Unternehmen wird gesagt, dass die Europäische Brieftasche für die Digitale Identität kommt, und fast niemand erklärt, was ein Unternehmen zuerst entscheiden sollte. Wenn Ihnen dieser Leitfaden geholfen hat, hilft eine ehrliche Bewertung dort, wo Sie ihn gekauft haben, anderen Lesenden, ihn zu finden.

Besuchen Sie **gdprgard.eu** für kostenlose Werkzeuge, Artikel und Neuigkeiten.

Anmerkungen und Quellen

1. Verordnung (EU) 2024/1183 vom 11. April 2024 zur Änderung der Verordnung (EU) Nr. 910/2014 (eIDAS) hinsichtlich der Schaffung des europäischen Rahmens für eine digitale Identität; in Kraft seit Mai 2024. Wallet für Privatpersonen freiwillig, selektive Offenlegung, Pseudonyme, Nutzer-Dashboard, kein Tracking durch Anbieter (Arbeitswissen und Sekundärzusammenfassungen; Artikelnummern bewusst nicht zitiert, weil der Text im Amtsblatt nicht direkt gelesen wurde).
2. Zeitplan und Akzeptanzpflichten: Mitgliedstaaten stellen bis Ende 2026 mindestens eine Wallet bereit (24. Dezember 2026 in mehreren Quellen; eine Anbieterquelle nennt den 31. Dezember); Akzeptanz durch regulierte private Relying Parties etwa 36 Monate nach den ersten Durchführungsrechtsakten, also Ende 2027; sehr große Online-Plattformen nach früherem Zeitplan; Eingeständnis der Kommission, dass nicht alle Länder voll bereit sein werden. Quellen: Kanzlei- und Anbieterbriefings über die Suche (Arthur Cox, Kennedys, eIDEAS, Start With Identity, Corbado, Fintech Global Juli 2026). Nicht gegen das Amtsblatt geprüft.
3. Durchführungsverordnung (EU) 2025/848 der Kommission vom 6. Mai 2025 über die Registrierung vertrauender Beteiligter der Wallets: Angabe der beabsichtigten Verwendung und der genauen Attributliste; die Abfrage nicht angegebener Daten ist ein Grund für die Aufhebung (Artikel 6); Registrierungszertifikate. Gesehen über Suchzusammenfassungen und Sekundärseiten (iGrant.io, EPICENTER.works, EUR-Lex-Index). Eine Änderung zu anwendbaren Standards wurde berichtet (eine Quelle nennt die Durchführungsverordnung (EU) 2026/1730, 15. Juli 2026) und konnte nicht bestätigt werden. Der Geltungsbeginn der detaillierten Regeln wird uneinheitlich berichtet (eine deutsche Quelle nennt den 24. Dezember 2026).
4. Architektur- und Referenzrahmen und zugehörige Spezifikationen: Nachweisformate SD-JWT VC und ISO/IEC 18013-5 mdoc; OpenID4VCI 1.0 und OpenID4VP 1.0 final; HAIP-Profil; Interoperabilitätsveranstaltungen bis 2026 (EUDI-Seite der OpenID Foundation; eudiw-Handbuch; Glossar des deutschen Entwicklerleitfadens; Suchzusammenfassungen). Eine Quelle behauptet, ARF 3.0.0 sei im Juli 2026 erschienen; unbestätigt. Pflichtattribute der PID aus Arbeitswissen aufgelistet.
5. Verordnung (EU) 2016/679 (DSGVO), Artikel 5 Absatz 1 Buchstaben c und e, 6, 9, 13–14, 25, 28, 32, 33, 35 und 44 ff. (Arbeitswissen; lesen Sie den Text).
6. Europäischer Datenschutzbeauftragter, förmliche Stellungnahme zum Entwurf einer Durchführungsverordnung zur Änderung der Durchführungsverordnung (EU) 2025/848, 17. April 2026: Beschreibungen der beabsichtigten Verwendung müssen konkret genug sein, um zu prüfen, dass die abgefragten Attribute erforderlich und verhältnismäßig sind (gesehen über Suchzusammenfassung; PDF nicht gelesen).
7. Europäischer Rechtsakt zur Barrierefreiheit, Richtlinie (EU) 2019/882: Pflichten für viele verbrauchernahe digitale Dienste ab dem 28. Juni 2025 (Arbeitswissen; Anwendungsbereich für Ihren Dienst prüfen).
8. DSGVO Artikel 33: Meldung einer Verletzung des Schutzes personenbezogener Daten an die Aufsichtsbehörde innerhalb von 72 Stunden, soweit möglich (Arbeitswissen).

9. Ob ein Wallet-Nachweis Pflichten zur Kundensorgfalt oder starken Authentifizierung in einem bestimmten Sektor erfüllt, hängt vom Recht dieses Sektors und seiner Aufsichtsbehörde ab (zum Beispiel Zahlungsdienste, Geldwäscheregeln); hier nicht analysiert.

Von der Autorin nicht überprüft: der genaue Text und die Artikelnummern der Verordnung (EU) 2024/1183; die genauen Wallet- und Akzeptanztermine in jedem Mitgliedstaat; der endgültige Text und der Geltungsbeginn der Durchführungsverordnung (EU) 2025/848 und ihrer Änderungen; welche Wallets an einem gegebenen Tag in welchen Ländern existieren; ob in Ihrem Mitgliedstaat Registrierungszertifikate ausgestellt werden; aktuelle Spezifikationsversionen; und wie eine bestimmte Branchenaufsicht Wallet-Nachweise behandeln wird. Marta, Adria Drive, Fenix Fitness, Klarheit Energie und alle Ereignisse in den Praxisbeispielen sind fiktiv.